TRAVAUX PRATIQUES

GOUVERNANCE, POLITIQUE DE SECURITE ET CADRE LEGAL

PAR : Hinmaka Nyeyambe et Njimongba Abdourahim

Lien GitHub : https://github.com/Abdosrad07/Systems-and-Networks-Security/tree/main/Dossier_Gouvernance_CamTrust_Bank

TP1.1 : inventaire et classification des actifs

Partie A : Découvrir ce qui existe vraiment

- R-SIEGE : show cdp neighbors detail

```
R-SIEGE#show cdp neighbors detail
-------------------------
Device ID: CHR
Entry address(es):
  IP address: 172.16.12.2
Platform: MikroTik,  Capabilities: Router
Interface: FastEthernet1/0,  Port ID (outgoing port): ether4
Holdtime : 108 sec

Version :
7.23.1 (stable) 2026-06-02 09:25:16

advertisement version: 1

R-SIEGE#
```

Figure 1 : Voisinage CDP sur R-SIEGE : identification de R-DLA/CHR (172.16.12.2, MikroTik RouterOS 7.23.1)

- R-DLA : /ip neighbor print detail

```
R-SIEGE | R-DLA
[admin@CHR] /user>
[admin@CHR] /user> /ip neighbor print detail
 0 interface=ether4 address=172.16.12.1 address4=172.16.12.1
   mac-address=C2:01:50:38:00:10 identity="R-SIEGE.camtrust.lab"
   platform="Cisco 3725"
   version="Cisco IOS Software, 3700 Software (C3725-ADVENTERPRISEK9-M),
        Version 12.4(15)T14, RELEASE SOFTWARE (fc2)\nTechnical Support:
        http://www.cisco.com/techsupport\nCopyright (c) 1986-2010 by Cisco
        Systems, Inc.\nCompiled Tue 17-Aug-10 12:08 by prod_rel_team"
   unpack=none age=46s interface-name="FastEthernet1/0" system-caps=""
   system-caps-enabled="" discovered-by=cdp
[admin@CHR] /user>
```

Figure 2 : Voisinage réseau sur R-DLA : identification de R-SIEGE (172.16.12.1, Cisco 3725)

- R-SIEGE : show ip dhcp binding

```
R-SIEGE#show ip dhcp binding
Bindings from all pools not associated with VRF:
IP address          Client-ID/              Lease expiration        Type
                    Hardware address/
                    User name
10.10.10.100        ffe2.343f.3e00.0200.    Mar 02 2002 12:03 AM    Automatic
                    00ab.11ec.fb77.9ed6.
                    d922.cc
10.10.10.101        0100.5079.6668.00       Mar 02 2002 12:21 AM    Automatic
R-SIEGE#
```

Figure 3 : Baux DHCP de R-SIEGE : attribution des adresses 10.10.10.100 et 10.10.10.101

- R-DLA : /ip dhcp-server lease print

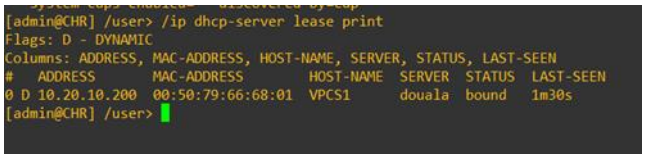


Figure 4 : Bail DHCP de VPCS1 sur R-DLA : adresse 10.20.10.200, état bound

- CLIENT-LINUX : nmap -sn 10.10.10.0/24 sudo nmap -sV 203.0.1.113.10



.Figure 5 : Scan Nmap du réseau 10.10.10.0/24 : seuls 10.10.10.1 et 10.10.10.100 sont actifs.

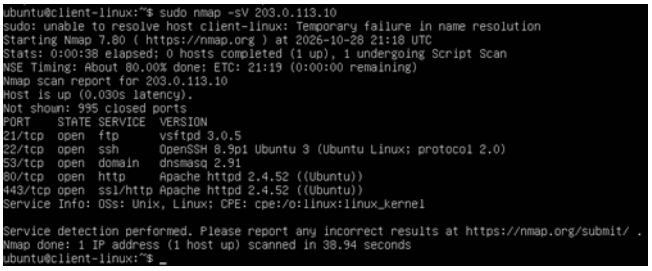


Figure 6 : Scan des services du serveur 203.0.113.10 : FTP, SSH, DNS, HTTP et HTTPS avec leurs versions.

Les équipements relevés :

Équipement	Modèle	Version logicielle	Adresse IP
R-SIEGE	Cisco 3725	Cisco IOS 12.4(15)T14	10.10.10.1 / 172.16.12.1 / 198.51.100.2
R-DLA	MikroTik CHR	RouterOS 7.23.1 (stable)	172.16.12.2 / 10.20.10.1
R-FAI	VyOS	VyOS rolling	198.51.100.1 / 203.0.113.1
SRV-INTERNET	VM Ubuntu 22.04.1	Apache 2.4.52, OpenSSH 8.9p1, dnsmasq 2.91, vsftpd 3.0.5	203.0.113.10
CLIENT-LINUX	VM Ubuntu 22.04.1	Ubuntu 22.04.1	10.10.10.100
PC-SIEGE	VPCS	IOS 12.4(15)T14	10.10.10.101
PC-DLA	VPCS	IOS 12.4(15)T14	10.20.10.200

SW-SIEGE	Cisco c3725 (Ethernet switch)	Cisco IOSvL2	-

Les différences entre les sources :

- R-DLA est visible uniquement via le voisinage réseau (CDP). Pas de bail DHCP, et il n'apparaît pas au scan nmap car il est sur le réseau 10.20.10.0/24, en dehors de la plage scannée.
- PC-DLA est visible uniquement via le bail DHCP de R-DLA. Le scan nmap ne le voit pas pour la même raison (hors plage scannée), et il n'a aucun lien CDP
- SRV-INTERNET est visible uniquement via le scan nmap. Il n'a pas d'interface sur le réseau du siège, donc ni CDP ni DHCP ne le concernent
- CLIENT-LINUX est visible en DHCP et au scan, mais pas en CDP
- PC-SIEGE apparaît en DHCP. Lors de mon scan nmap il était absent, lors d'un autre il était présent : le résultat dépend de l'état du cache ARP et du filtrage ICMP au moment du scan

Pourquoi on croise toujours plusieurs sources :

Une seule source ne suffit jamais, parce que chacune ne montre qu'une partie du réseau :

- Le voisinage réseau (CDP/LLDP) ne liste que les équipements voisins qui parlent le protocole. Si le protocole est désactivé sur un équipement, il devient invisible
- Le DHCP donne les adresses attribuées, mais garde l'entrée même si la machine est éteinte (le bail dure 24 h). On peut donc voir des postes qui n'existent plus.
- Le scan nmap ne voit que les machines qui répondent au moment du scan, et un pare-feu ou un filtrage ICMP peut les rendre invisibles.

En croisant les trois, on supprime les faux positifs (un bail DHCP périmé) et on rattrape les faux négatifs (une machine que le scan ne voit pas mais qui a une adresse attribuée). Et quand les sources ne concordent pas, c'est souvent le signe qu'un équipement n'est pas déclaré ou n'est pas administré

Partie B : construire l'inventaire de CamTrust Bank

ID	Actif	Type	VM	Site	Adresse IP	Version	Propriétaire	Fin support	Crit.
VM-01	Gérer les comptes clients / core banking	Valeur métier	/	/	/	/	Directeur des opérations	/	4
VM-02	Traiter les transactions Mobile Money	Valeur métier	/	/	/	/	Responsable Mobile Money	/	4
VM-03	Traiter paiements et retraits par carte	Valeur métier	/	/	/	/	Responsable monétique	/	4
VM-04	Assurer la messagerie interne	Valeur métier	/	/	/	/	DSI	/	3
VM-05	Publier les informations institutionnelles	Valeur métier	/	/	/	/	Responsable communication	/	2

VM-06	Fournir le Wi-Fi aux clients en agence	Valeur métier	/	/	/	/	DSI	/	3
BS-01	Routeur R-SIEGE, Cisco 3725	Bien support	1,0–03	Yaoundé	10.10.10.1 ; 172.16.12.1	IOS 12.4(15)T14	DSI	Dépassée	4
BS-02	Routeur R-DLA / CHR	Bien support	1,0–03	Douala	172.16.12.2	RouterOS 7.23.1	DSI	N/R	4
BS-03	Serveur web/DNS du lab	Bien support	5	Siège/DMZ	203.0.113.10	Ubuntu ; Apache 2.4.52 ; dnsmasq 2.91	DSI	N/R	2
BS-04	Poste CLIENT-LINUX	Bien support	1,0, 04	Yaoundé	10.10.10.100	Ubuntu, version N/R	Responsable back-office	N/R	4
BS-05	Poste détecté par DHCP	Bien support	1	Yaoundé	10.10.10.101	N/R	Responsable back-office	N/R	4
BS-06	Poste VPCS1	Bien support	1	Douala	10.20.10.200	N/R	Chef d'agence Douala	N/R	4
BS-07	Serveur core banking	Bien support	1	Yaoundé	N/R	N/R	DSI	N/R	4
BS-08	Serveur passerelle Mobile Money	Bien support	2	Yaoundé	N/R	N/R	DSI	N/R	4
BS-09	Plateforme de monétique	Bien support	3	Yaoundé	N/R	N/R	DSI	N/R	4
BS-10	Serveur de messagerie	Bien support	4	Yaoundé	N/R	N/R	DSI	N/R	3
BS-11	Pare-feu et concentrateur VPN du siège	Bien support	1,0–03	Yaoundé	N/R	N/R	DSI	N/R	4
BS-12	Routeur de l'agence de Garoua	Bien support	1,0–03	Garoua	N/R	N/R	DSI	N/R	4
BS-13	Borne Wi-Fi clients de Douala	Bien support	6	Douala	N/R	N/R	DSI	N/R	3
BS-14	Borne Wi-Fi clients de Garoua	Bien support	6	Garoua	N/R	N/R	DSI	N/R	3

N/R : information non relevée pendant le TP

Partie C : grille DICP et classification

Service	**D**	**I**	**C**	**P**	**Justification métier**	**Criticité**
Core banking	4	4	4	4	Arrêt = agences fermées ; erreur = pertes financières ; données et opérations à tracer	4
Mobile Money	4	4	3	4	Transactions immédiates et litiges nécessitant des preuves	4
Monétique	4	4	4	4	Indisponibilité ou fraude = pertes ; données cartes sensibles et opérations contestables	4
Messagerie interne	3	3	3	2	Outil quotidien contenant des échanges confidentiels	3
Site institutionnel	2	3	1	1	Contenu public ; une défiguration nuit à l'image	2
Wi-Fi clients	1	1	1	3	Service de confort, mais connexions à tracer	3

Analyse des risques

N°	Scénario (source retenue)	Grav.	Vrais.	Niveau	Traitement	Résiduel
R1	Rançongiciel via un poste d'agence (S1 cybercriminels)	4	4	**16**	Réduction	8
R2	Fraude interne sur le lien agence (S3 employé)	4	3	**12**	Réduction	6
R3	Indisponibilité du lien Internet un jour de paie (S1 / panne)	4	3	**12**	Réduction + transfert	6
R5	Compromission des services exposés web/FTP/DNS (S1, S4)	3	3	**9**	Réduction	4
R4	Fuite de données clients vers un service étranger non validé (S3)	4	2	**8**	Éviction + réduction	4
R6	Accès de prestataire non maîtrisé (S4 prestataire)	3	2	**6**	Réduction	3

Budget demandé : 8 900 000 FCFA sur 12 mois — cloisonnement des réseaux et du Wi-Fi invité 3 500 000 · journalisation, temps et sauvegarde des configurations 1 500 000 · sauvegarde chiffrée hors site 1 800 000/an · liaison 4G de secours 900 000/an · durcissement et comptes nominatifs 1 200 000.

Risques résiduels à accepter : quelques heures d'interruption malgré la liaison de secours ; une collusion de deux comptes autorisés ; un poste non recensé jusqu'au 31/01/2027.